



ISC 互联网安全大会



360 互联网安全中心

AI 攻防对现有身份认证技术的挑战

冯继强 锦佰安科技CEO

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

目录

AI 攻防对现有身份认证技术的挑战

- 一、身份认证在网络安全中的重要性
- 二、现有身份认证的逻辑和流程
- 三、人工智能学习技术针对该防御模型的对抗攻击
- 四、创新的防御手段



ISC 互联网安全大会



360 互联网安全中心

一、身份认证在网络安全中的重要性

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE TECHNOLOGY
PERSONAL PRIVACY IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

On the internet,
nobody knows
You're a dog.

身份认证是指登录计算机网络时系统对用户身份的确认技术。是网络安全的第一道防线，也是最重要的一道防线。

ZERO TRUST SECURITY



NOLOGY
RITY

北京
hina
ATION



ISC 互联网安全大会



360 互联网安全中心

二、现有身份认证的逻辑和流程

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE TECHNOLOGY
PERSONAL PRIVACY IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

现有身份认证的逻辑和流程

test123

.....

验证码

EXML 换一张

☒ 下次自动登录

登录遇到问题

登录

认证的本质？

红色：身份认证（区别人和人）

蓝色：人机识别（区别人和机器）

人和机识别的具体方式和场景

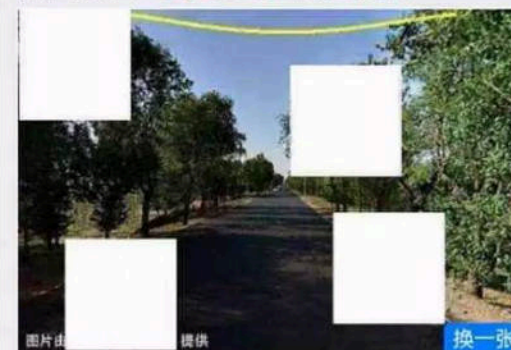
字符型验证码
复杂图形拼图
文字点按+拼图
滑动拼图
点击+滑动
.....



拖动下方滑块完成拼图



为确保帐号安全, 请完成以下安全验证:
拼图提示: 长按拖动, 点击旋转



确定



依次点击 "烈" "份" "否"

热水袋



人与人相互区分的方式和场景

帐号+密码
手机短信验证码
OTP动态口令
U盾
.....



中国联通 09:51

×

账号密码登录

请输入手机号

请输入密码

登录

手机快捷登录 | 忘记密码

注册/登录即代表同意《用户协议》

信息 95511
尊敬的客户，您正在使用 APP，
码：188819，有效期2分钟。【

健康无价

130 6

请输入验证码

登录

1 2 ABC
4 GHI 5 JKL
7 PQRS 8 TUV
0

中国联通 09:52 45%

身份验证器

Google

128 344

st en@gmail.com



ISC 互联网安全大会



360 互联网安全中心

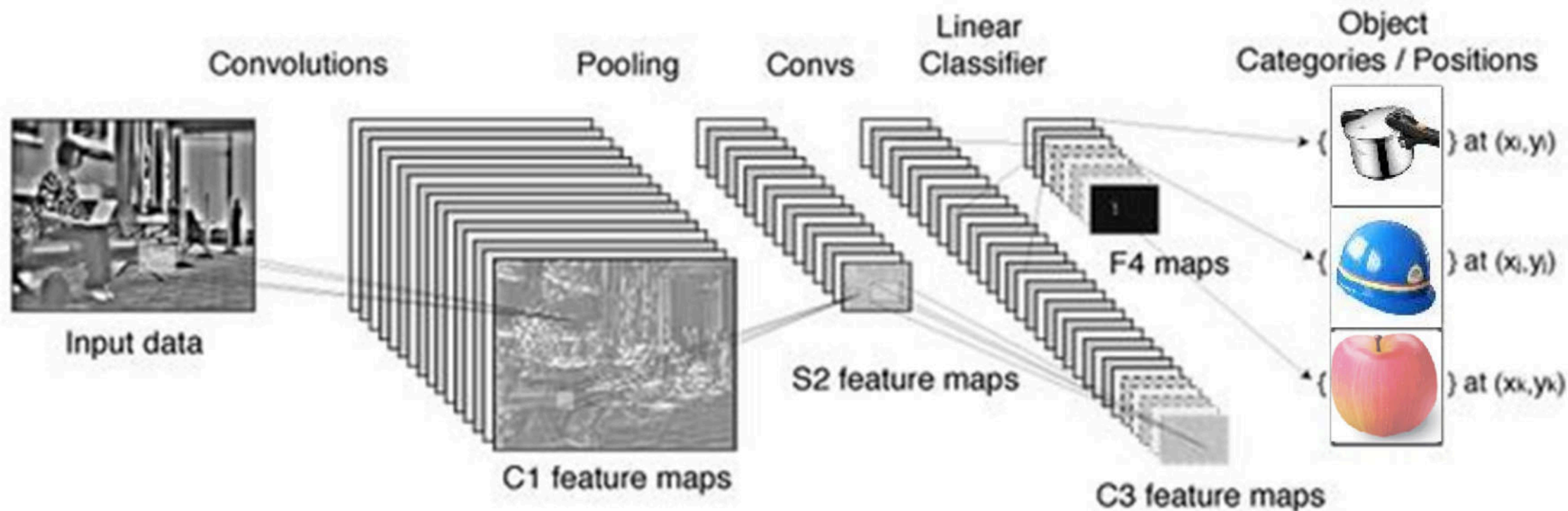
三、人工智能学习技术针对该防御模型的对抗攻击

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

人工智能学习技术对该防御模型的对抗攻击

最初 CNN 卷积神经网络识别验证码
大量学习样本



模型训练过程：

- 1.首先收集500张滑动图片，人肉滑动100张，从浏览器中获取正确的拼图坐标点和滑动轨迹。
- 2.把大图中的拼图缺块区域切割出来，作为正例，把拼图的小块作为反例。把训练数据放到CNN网络中训练识别模型。
- 3.把其他搜集到的图片放入模型中识别，把识别不准确的图片 缺块区域抠出来 重新训练。
- 4.爬取更多的图片进行训练和识别，反复迭代，提高准确率。

破解过程：

1. 用浏览器测试框架获取当前验证图片，用之前训练好的模型寻找 缺块坐标点
2. 运用之前搜集的滑动轨迹和坐标点，通过GAN生成的轨迹，控制鼠标滑动。（后来发现可以通过让鼠标模拟微微抖动的方式绕过）

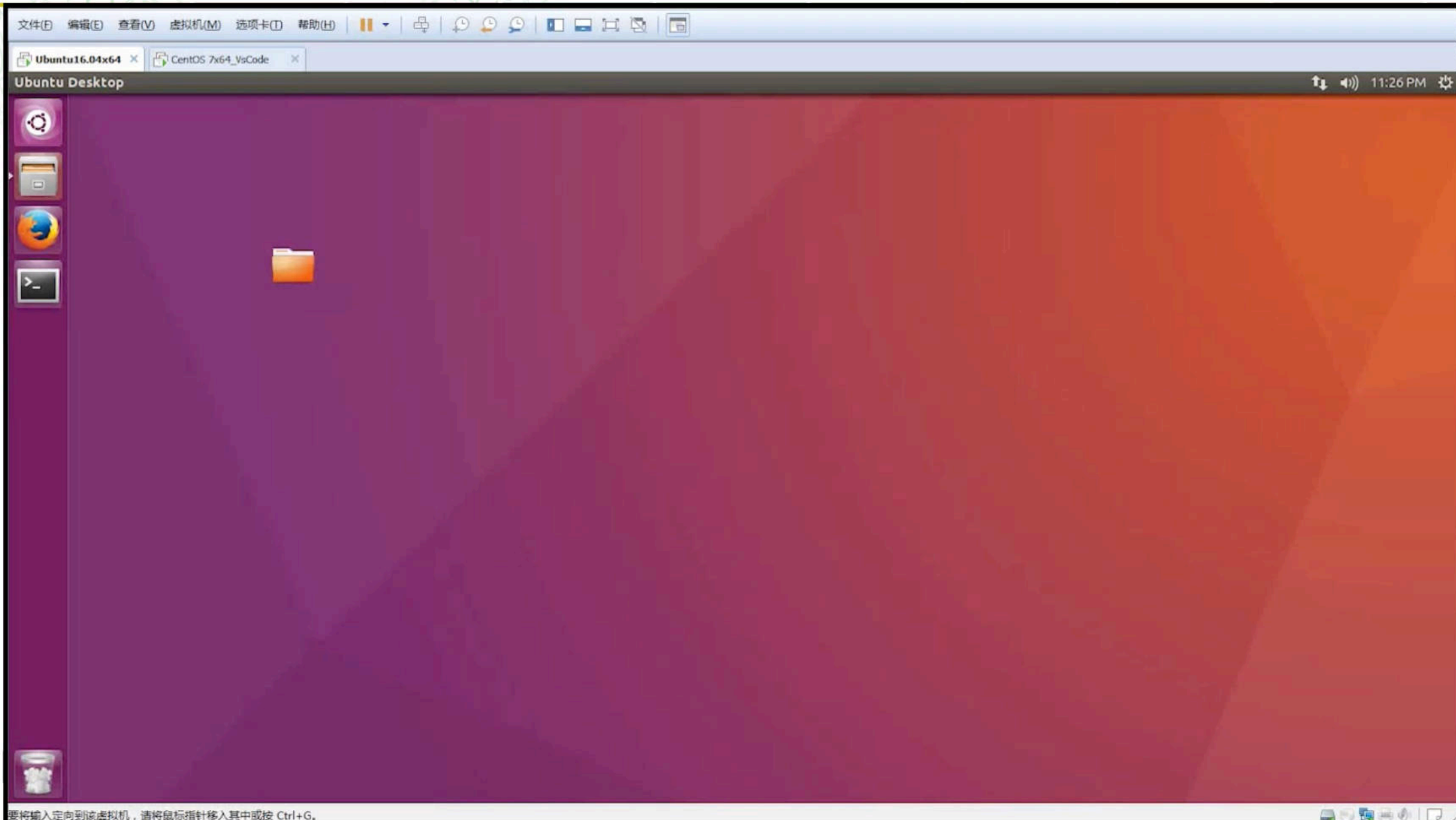
利用人工智能技术绕过滑动验证码



ISC 互联网安全大会

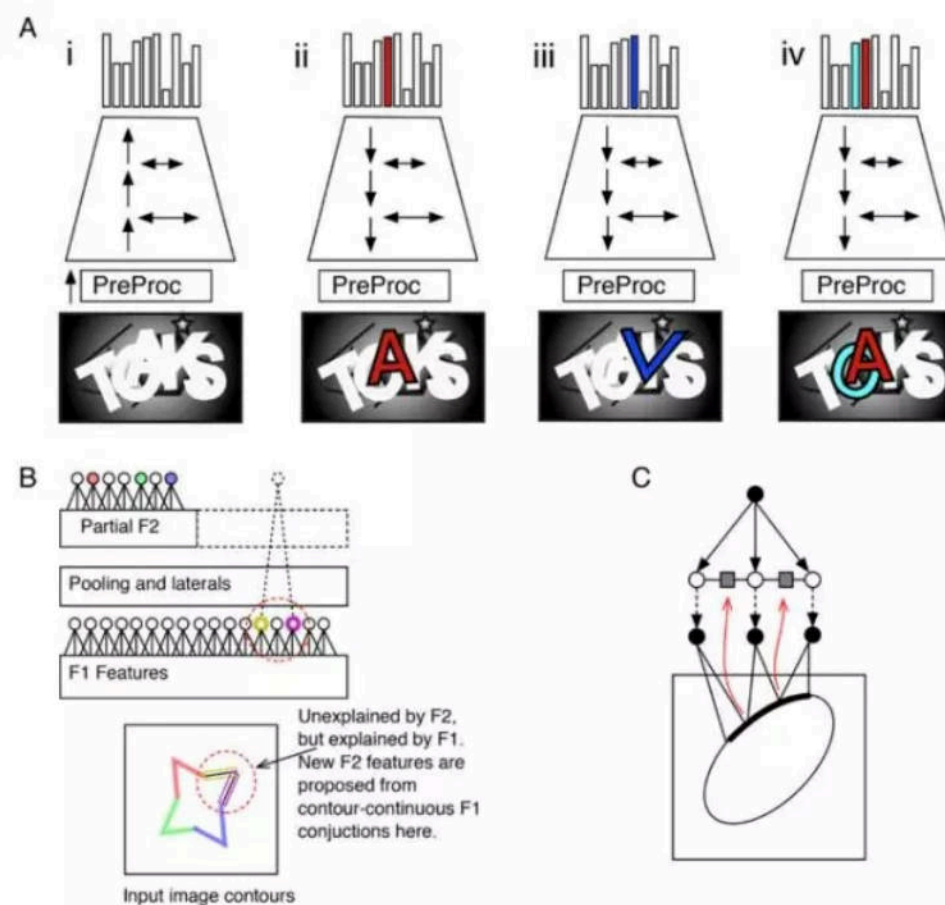
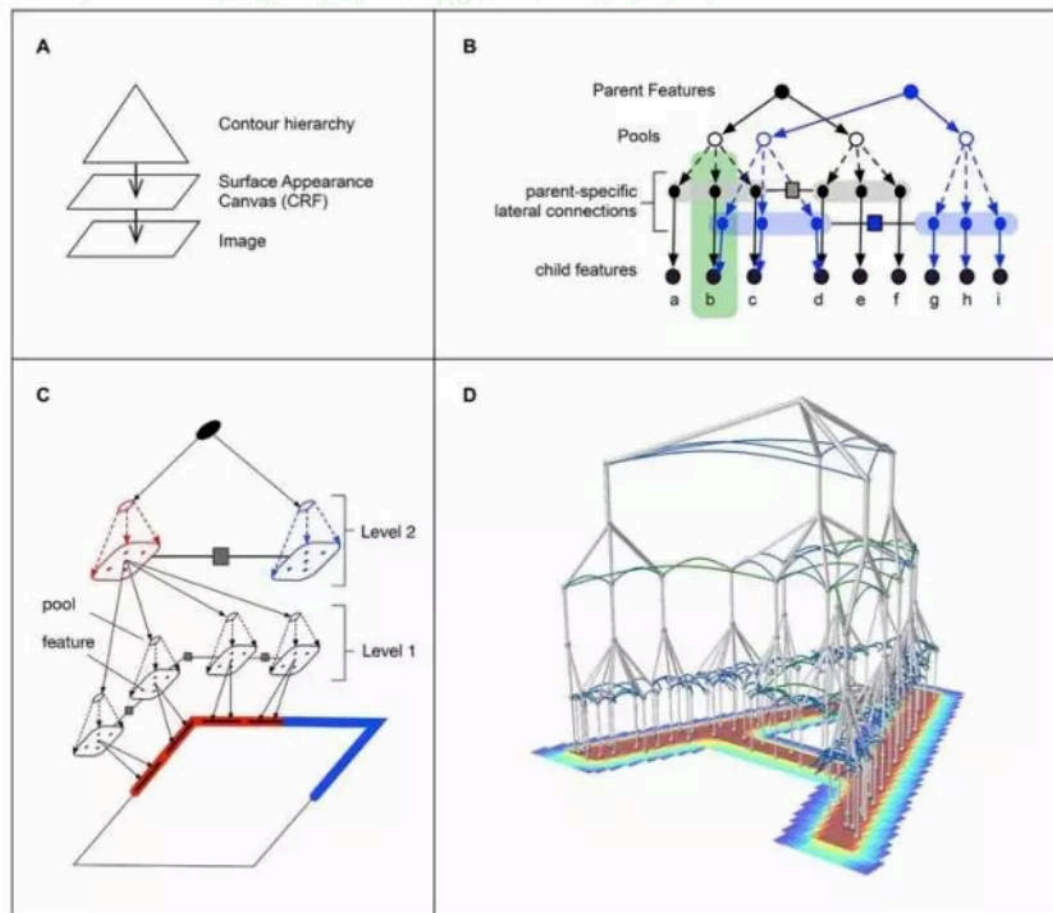


360 互联网安全中心



RCN框架 极少量样本快速学习

整体上以300倍的数据有效性击败了深度学习的卷积网络模型



ZERO TRUST SECURITY

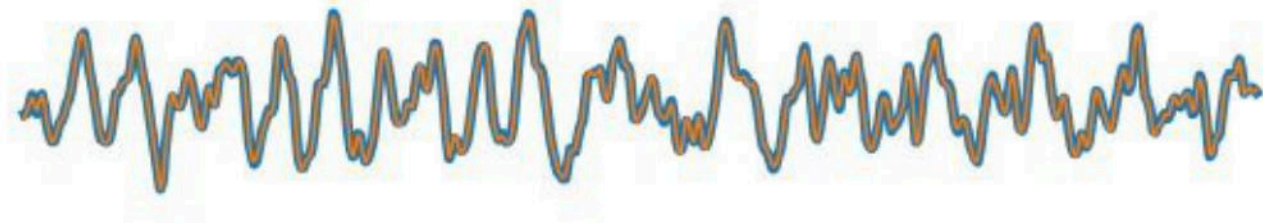
GOOGLE AI 语音识别 对 语音验证码的攻击

针对语音识别 AI 的新型攻击方法

Nicholas Carlini和 David Wagner来自美国加州大学伯克利分校的计算机科学家「骗」过了Mozilla推出的 DeepSpeech文字转语音系统。

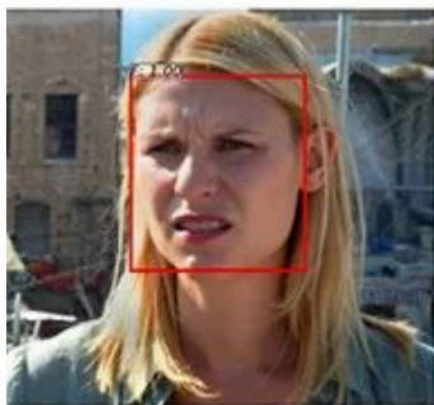
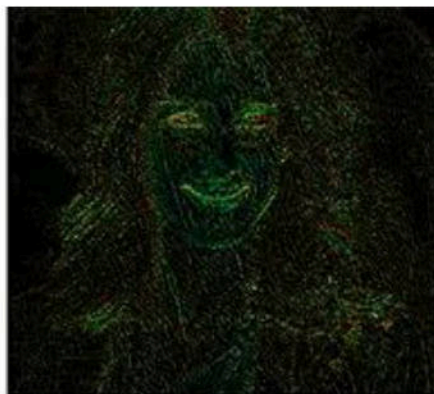
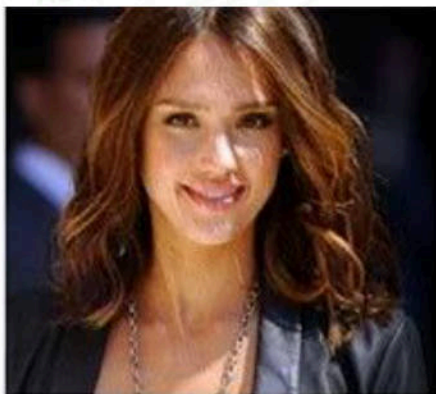
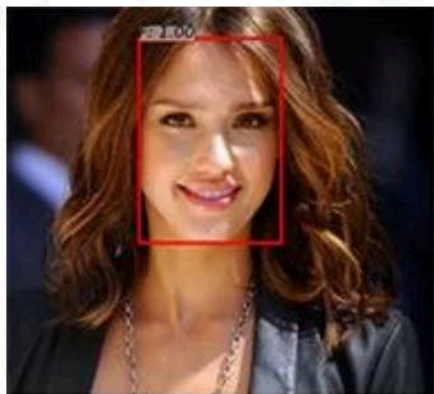
算法生成音频的波形（橙色）与原始音频波形（蓝色）近乎完全一致，所表达的内容却完全不同。

也就是说，从GoogleAssistant到亚马逊Alexa再到苹果 Siri，由于当下市面上几乎所有语音助手都会用到文字转语音技术，研究人员也可以使用同样的方法来「欺骗」这些语音助手。



GAN (GENERATIVE ADVERSARIAL NETWORK)

生成对抗网络 模型 对 现有的图形类真实性验证攻击挑战



Original

Modified

Difference

多伦多大学Parham Aarabi教授和研究生Avishek Bose的团队开发了一种算法，可以动态地破坏人脸识别系统，通过动态地干扰人脸识别工具来保护用户的隐私。

他们的解决方案利用了一种叫做对抗训练（adversarial training）的深度学习技术，这种技术让两种人工智能算法相互对抗，将微小的干扰（perturbation）添加到输入的人脸图像中，会导致预训练过的人脸探测器失效。

CYCLEGAN人脸和视频真实性挑战



ISC 互联网安全大会

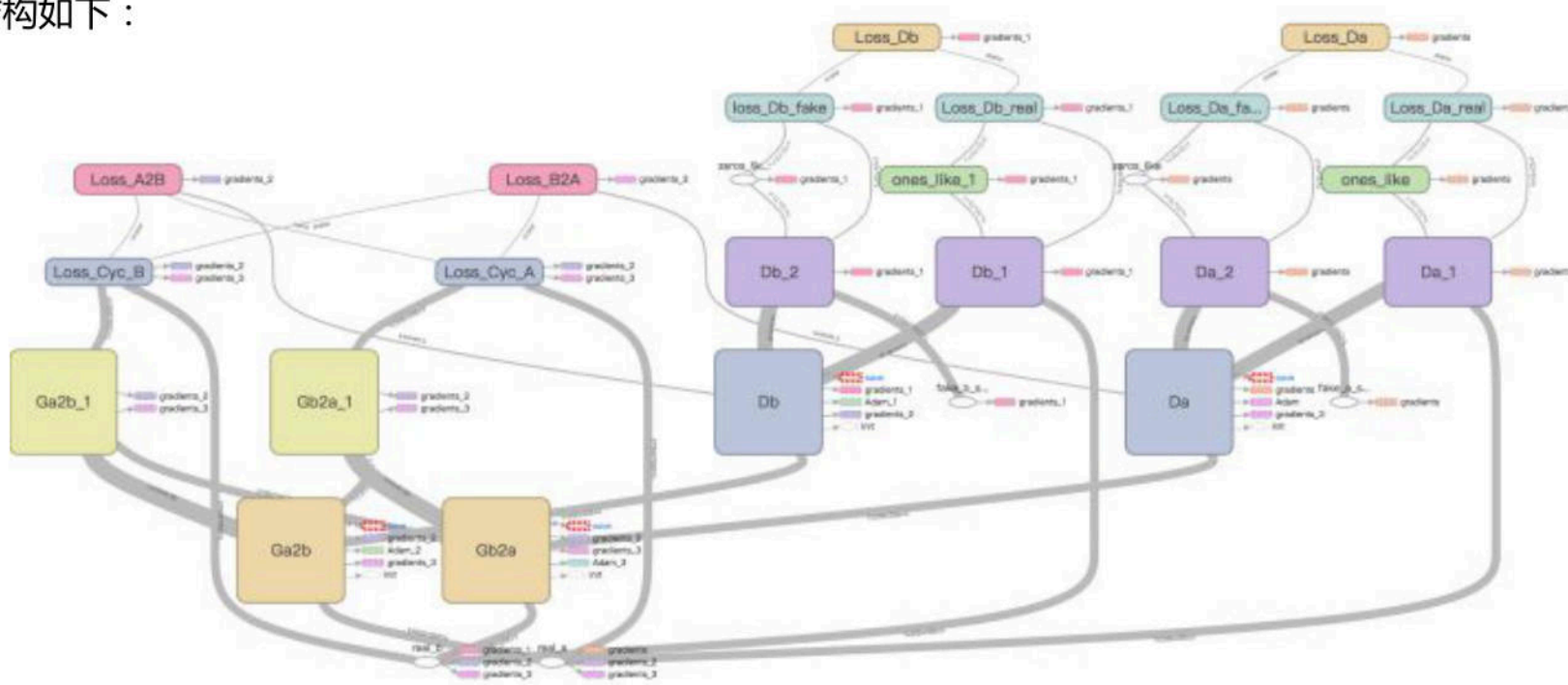


360 互联网安全中心

AI换脸之CycleGAN

CycleGAN的原理可以概述为：**将一类图片转换成另一类图片**。也就是说，现在有两个样本空间，X和Y，我们希望把X空间中的样本转换成Y空间中的样本。

具体网络结构如下：



ZERO TRUST SECURITY

WEB INTERNET
LEAK
IGE
CY
IDENTITY SECURITY
ITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

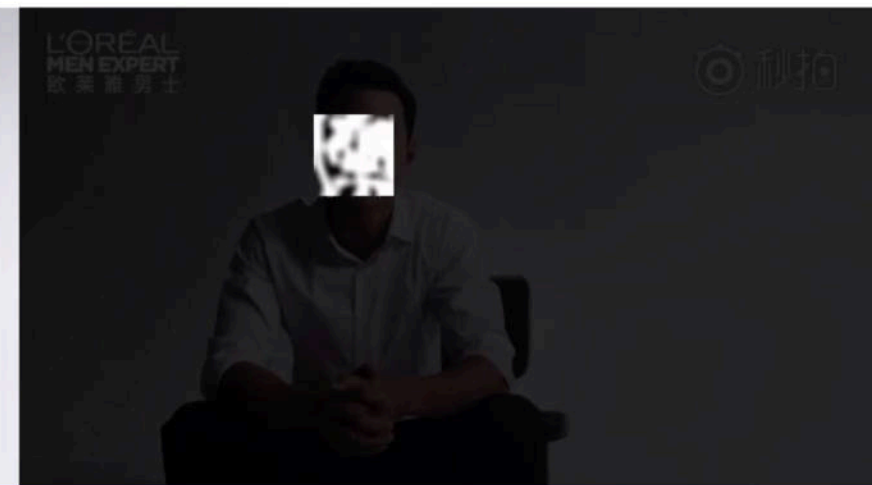
CYCLEGAN人脸和视频真实性挑战（视频演示）

人工智能可伪造极度仿真的公众人物的表情、神态及动作，生成难以识别的虚假视频

吴彦祖本人

员工小明

AI换脸



视频：AI合成仿真活体视频

PASSGAN 利用GAN算法针对现有密码生成框架规则的高效攻防



ISC 互联网安全大会



360 互联网安全中心

PassGAN，一项利用 GAN 改善密码破解的全新技术，提出使用基于机器学习的理论式密码生成方法代替人类的密码规则。PassGAN 通过一系列的泄露密码训练 GAN 生成破解密码。由于 GAN 的输出紧密分布在训练集上，使用 PassGAN 生成的密码很可能匹配未被泄漏的密码。由于从密码数据而不是人为分析自动推断密码分布信息，PassGAN 可观地提升了基于规则的密码生成工具的效率，从而可以毫不费力地利用新的泄漏密码生成更丰富的密码分布。

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE
PERSONAL PRIVACY
IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL



ISC 互联网安全大会



360 互联网安全中心

四、创新的防御手段

ZERO TRUST SECURITY

WEB INTERNET
INFORMATION LEAK
TERMINAL AGE TECHNOLOGY
PERSONAL PRIVACY IDENTITY SECURITY
IDENTITY
AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China
INDUSTRIAL

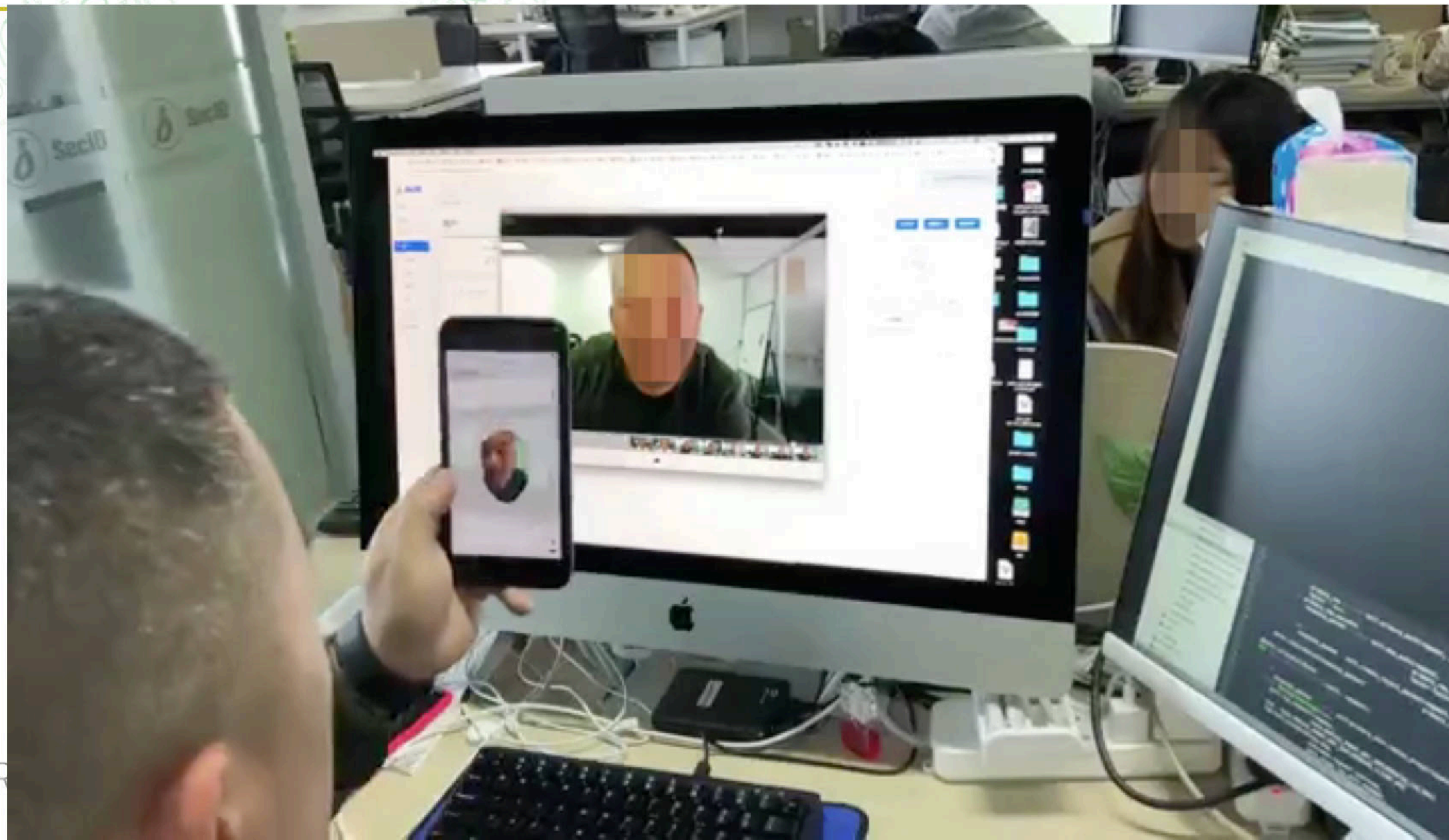
人脸识别挑战 - 活体检测攻击和绕过



ISC 互联网安全大会



360 互联网安全中心



TECHNOLOGY
SECURITY

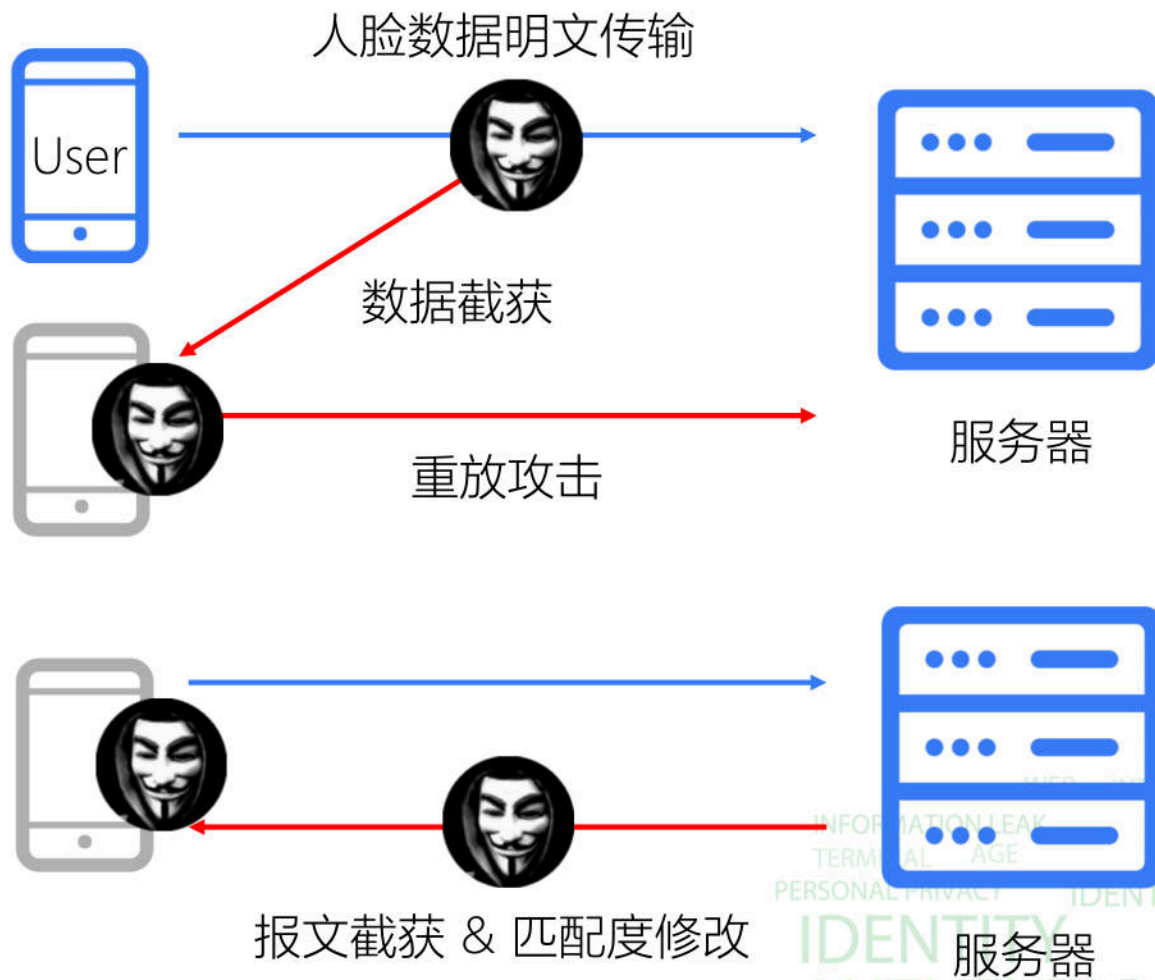
ON
国·北京
g·China
OPERATION

ZER

人脸识别挑战 - 服务器交互过程攻击

很多APP或SDK在上传拍摄的照片时，明文传输，且没有对图像数据进行签名，导致图像数据可以被截获篡改，有的在数据报文没有加入时间戳，可以通过重放数据报文的方式来实施破解。

我们在测试某款应用的过程中，甚至出现过这样的情况：本地上传人脸数据到服务器，服务器返回一个匹配度，本地通过匹配度来决定人脸识别是否通过，该应用没有对数据报文加签名，导致返回数据可以被轻松篡改，最终绕过人脸检测。



人脸识别挑战 - 3D打印绕过结构光检测



ZERO TRUST SECURITY

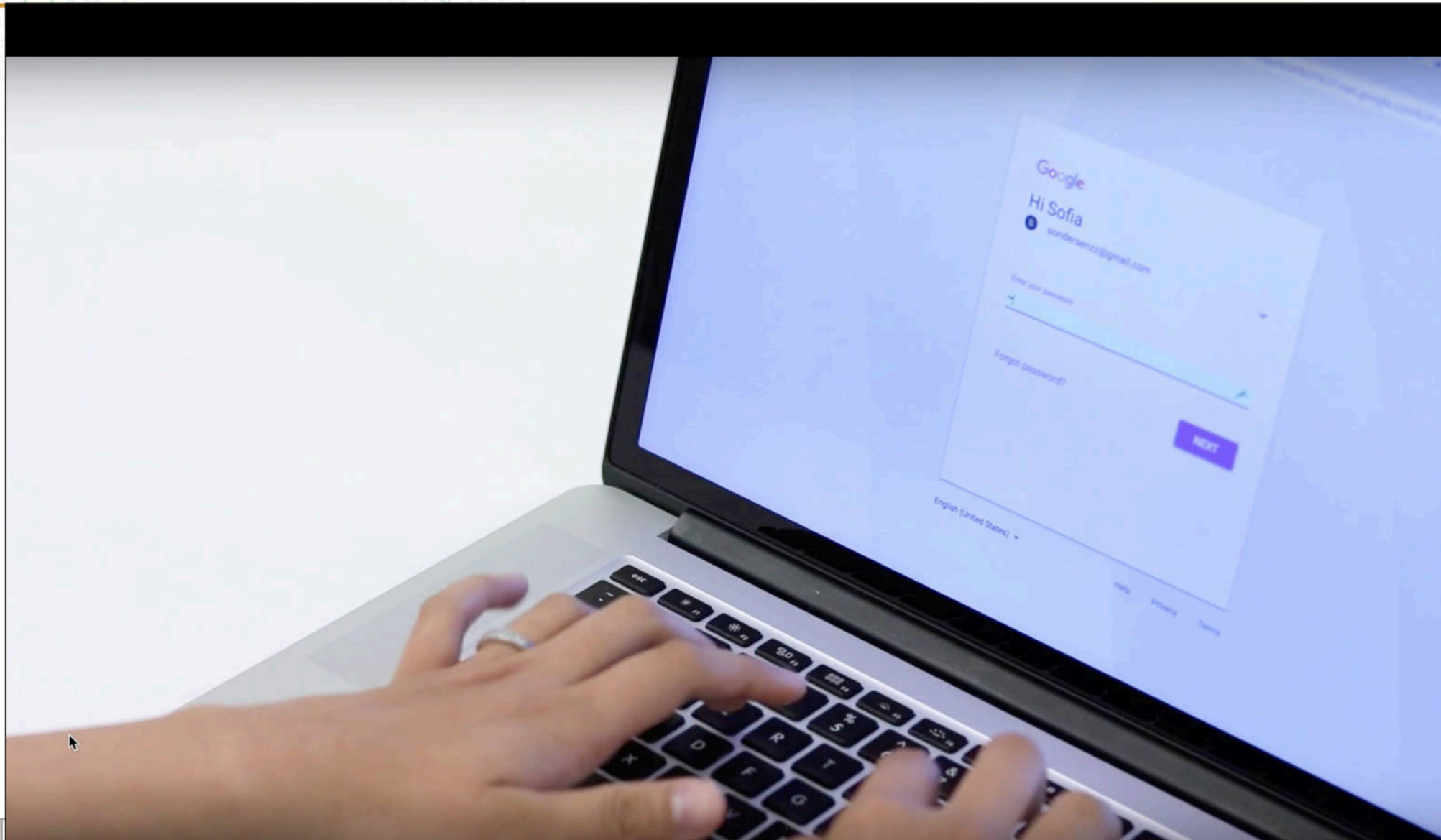
防御新技术的应用 – GOOGLE



ISC 互联网安全大会



360 互联网安全中心



ZERO T

INTERNET

TECHNOLOGY

SECURITY SECURITY

INFORMATION

中国·北京

Beijing·China

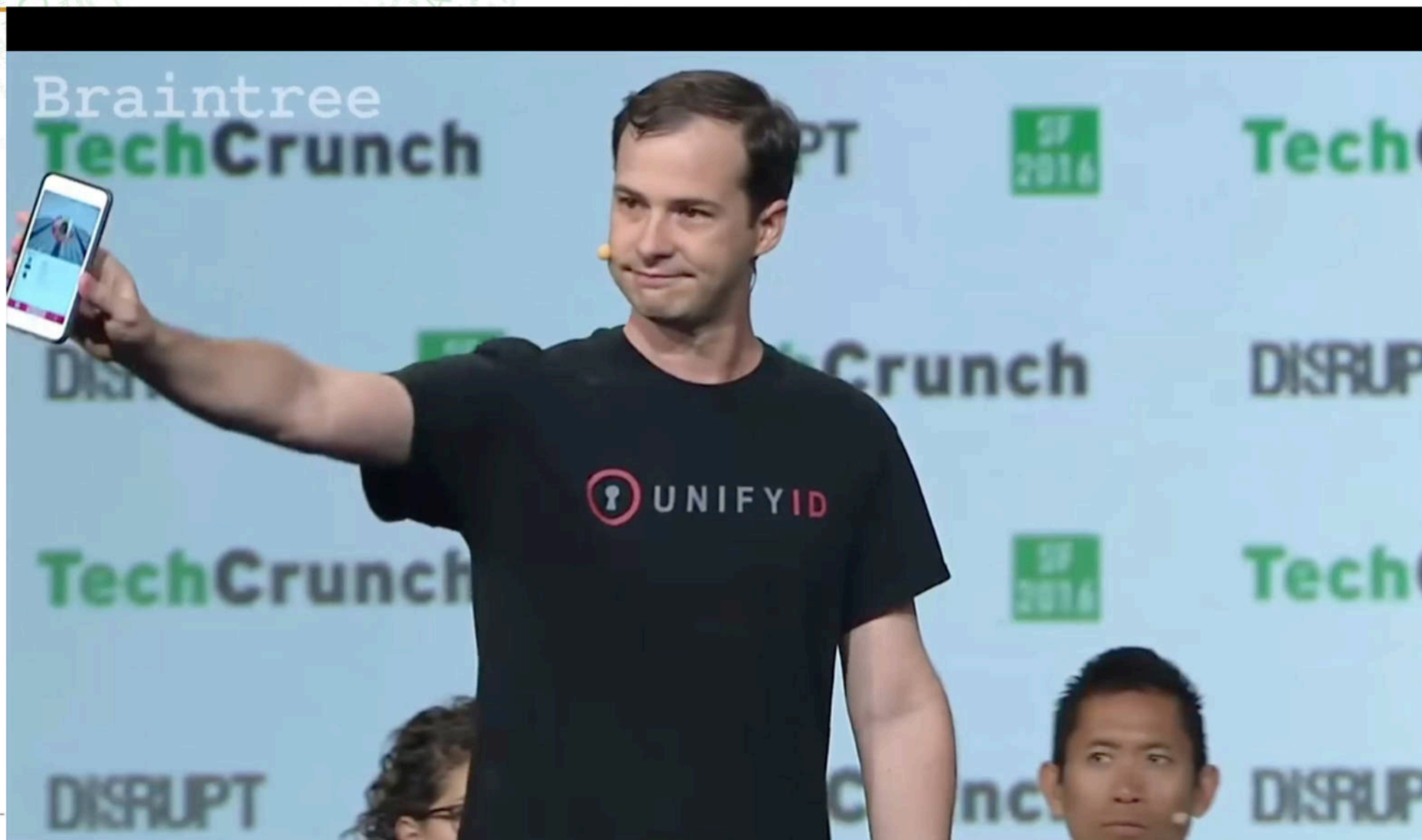
防御新技术的应用 – UNIFY ID



ISC 互联网安全大会



360 互联网安全中心



ZERO T

NET

TECHNOLOGY

TY SECURITY

ATION

中国·北京

Beijing·China

防御新技术的应用 – SECID 移动端



ISC 互联网安全大会



360 互联网安全中心



TECHNOLOGY
SECURITY

· 北京
China

防御新技术的应用 – SECID PC端



ISC 互联网安全大会



360 互联网安全中心



AI行为识别身份认证演示

alice

●●●●

密码: 12345678

确认登录

登录AI行为识别身份认证演示系统



防御新技术的业务场景

针对业务场景 结合设备、多种认证交叉验证来实现可信、可控验证方案

用户

注册

登录

修改 / 找回

支付 / 转账



ZERO TRUST SEC

注册

请输入手机号

请输入验证码 [发送](#)

[已经是买单吧用户 立即登录](#)

[立即注册](#)

☒ 本人已阅读，知晓并同意遵守服务条款

[遇到问题](#)

登录

151****5215

[忘记密码](#)

请输入登录密码

[登录](#)

[注册](#)

设置登录密码

手机号: 153 **** 5076

新密码 (6-15位数字或字母)

确认密码

手机验证码 [发送验证码](#)

*修改后请使用新密码登录交通银行信用卡 | 买单吧、交通银行信用卡官网以及积分乐园

[完成](#)

支付

收款方 严

请输入您的支付密码

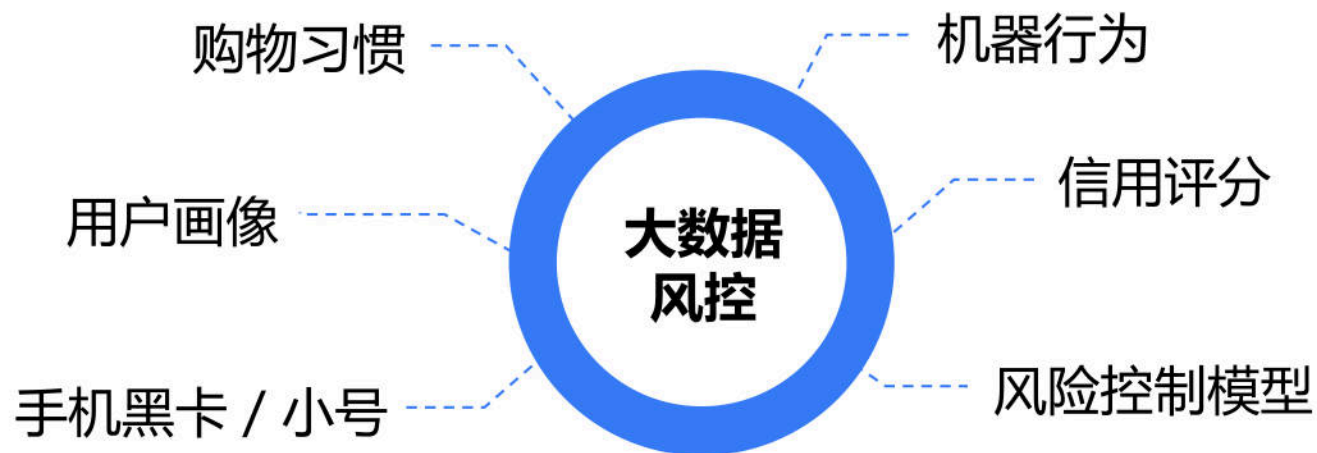
[取消](#)

支付金额 10,000,000.00 元

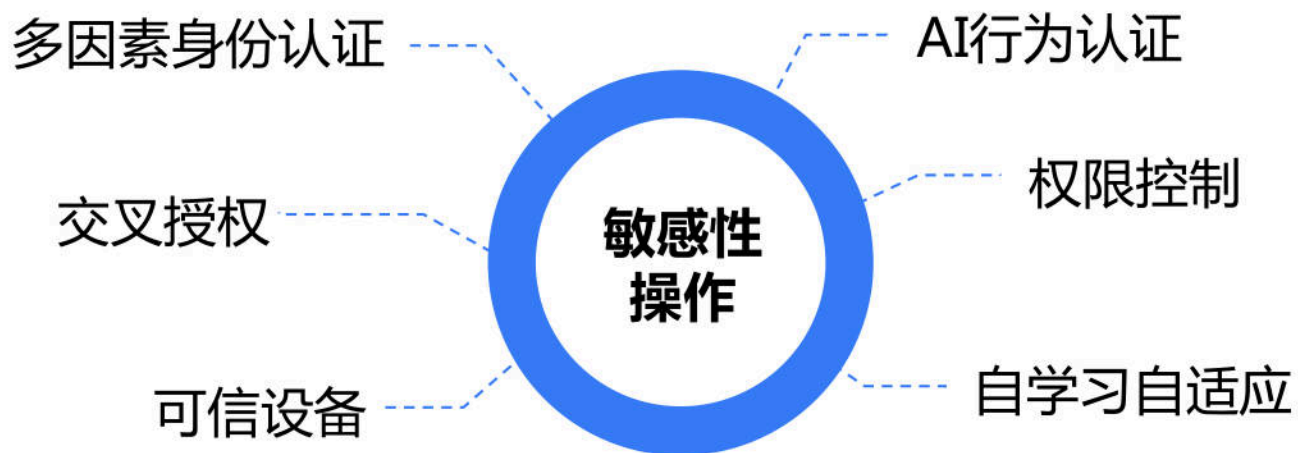
收款户名: 严

1	2 ABC	3 DEF
4 GHI	5 JKL	6 MNO
7 PQRS	8 TUV	9 WXYZ
	0	X

防御新技术的业务场景



防御新技术的业务场景



ZERO TRUST SECURITY



ISC 互联网安全大会



360 互联网安全中心

谢谢！

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing · China